

Analyse du Scan Trivy - Instana Agent 1.316.1

Résumé Exécutif

Image analysée: `instana-agent-1.316.1.tar`

Base OS: Red Hat Enterprise Linux 8.10

Date du scan: 2026-04-15

Outil: Trivy 0.69.3

Statistiques des Vulnérabilités

Sévérité	Nombre	Pourcentage
CRITICAL	0	0%
HIGH	9	3.3%
MEDIUM	110	39.9%
LOW	157	56.9%
TOTAL	276	100%



Analyse Détaillée



Points Positifs

1. **Aucune vulnérabilité CRITICAL** détectée
2. **Dépendances Java saines** - Tous les fichiers JAR (sensors Instana) montrent 0 vulnérabilité
3. **Image de base officielle** - Red Hat UBI 8.10 avec support officiel



Vulnérabilités HIGH (9 CVEs)

Les 9 vulnérabilités HIGH identifiées concernent principalement les bibliothèques système de RHEL 8.10 :

1. libnghttp2 - CVE-2026-27135

- **Package:** libnghttp2 1.33.0-6.el8_10.1
- **Impact:** Dénî de service via frames HTTP/2 malformées
- **Statut:** **Correctif disponible** → 1.33.0-6.el8_10.2
- **Action:** **MISE À JOUR RECOMMANDÉE**

2. libcap - CVE-2026-4878

- **Package:** libcap 2.48-6.el8_9
- **Impact:** Escalade de privilèges via race condition TOCTOU
- **Statut:** affected
- **Action:** Surveiller les mises à jour Red Hat

3-4. libarchive - CVE-2026-4424, CVE-2026-33948

- **Package:** libarchive 3.3.3-6.el8_10
- **Impact:** Divulgence d'informations, lecture hors limites
- **Statut:** affected
- **Action:** ⚠ Surveiller les mises à jour

5-9. Autres bibliothèques système

- Vulnérabilités dans curl, glibc, jq avec statut "affected"
- Pas de correctifs immédiats disponibles

Packages Critiques à Surveiller

Bibliothèques Réseau et Sécurité

curl/libcurl (7.61.1-34.el8_10.11) - 6 CVEs MEDIUM

- CVE-2025-13034: Contournement du pinning de clé publique
- CVE-2025-14017: Bypass de sécurité TLS multi-thread
- CVE-2026-1965: Bypass d'authentification Negotiate
- CVE-2026-3783: Fuite de token OAuth2
- CVE-2026-3784: Réutilisation incorrecte de connexion proxy
- CVE-2026-3805: Use-after-free

glibc (2.28-251.el8_10.31) - 3 CVEs MEDIUM

- CVE-2026-4046: DoS via fonction iconv()
- CVE-2026-4437: Parsing DNS incorrect
- CVE-2026-4438: Hostname DNS invalide

libssh (0.9.6-16.el8_10) - 5 CVEs MEDIUM

- CVE-2025-5351: Double free
- CVE-2025-8114: Déréférencement NULL pointer
- CVE-2026-0964: Sanitization incorrecte des chemins SCP
- CVE-2026-0966: Buffer underflow
- CVE-2026-3731: Lecture hors limites

Utilitaires Système

jq (1.6-11.el8_10) - 5 CVEs MEDIUM

- CVE-2026-39979: Lecture hors limites
- CVE-2026-40164: DoS via collisions de hash
- CVE-2026-32316: Overflow entier + buffer overflow
- CVE-2026-33947: Récursion non bornée

- CVE-2026-39956: Crash et divulgation mémoire

gnupg2 (2.2.20-4.el8_10) - 4 CVEs MEDIUM

- CVE-2025-68972: Bypass de signature
- CVE-2022-3219: DoS via paquets compressés
- CVE-2025-30258: DoS de vérification
- CVE-2026-24883: DoS via paquet de signature

Plan d'Action Recommandé

Actions Immédiates (Priorité 1)

1. Mettre à jour libnghttp2

```
microdnf update libnghttp2
```

Ceci corrige la seule vulnérabilité HIGH avec correctif disponible.

2. Reconstruire l'image avec les dernières mises à jour RHEL 8.10

```
RUN microdnf upgrade -y && microdnf clean all
```

Actions à Court Terme (Priorité 2)

3. Surveiller les advisories Red Hat

- S'abonner aux notifications RHSA (Red Hat Security Advisory)
- URL: <https://access.redhat.com/security/security-updates/>

4. Planifier une mise à jour vers RHEL 9

- RHEL 8.10 est en fin de cycle de vie standard
- RHEL 9 offre des versions plus récentes des bibliothèques système
- Considérer la migration vers `ubi9-minimal` comme image de base

Actions Continues (Priorité 3)

5. Automatiser les scans de sécurité

```
# Scan régulier avec Trivy
trivy image --severity HIGH,CRITICAL
containers.insta.io/instana/release/agent/static:1.316.1
```

6. Implémenter une politique de mise à jour

- Scans hebdomadaires automatisés
- Mise à jour mensuelle des images de base
- Tests de régression après chaque mise à jour

7. Monitoring runtime

- Activer les contrôles de sécurité runtime (AppArmor/SELinux)
- Limiter les capacités du conteneur
- Utiliser des network policies restrictives

Mesures de Mitigation

Configuration Kubernetes Recommandée

```
apiVersion: v1
kind: Pod
metadata:
  name: instana-agent
spec:
  securityContext:
    runAsNonRoot: true
    runAsUser: 1000
    fsGroup: 1000
    seccompProfile:
      type: RuntimeDefault
  containers:
  - name: instana-agent
    image: containers.instana.io/instana/release/agent/static:1.316.1
    securityContext:
      allowPrivilegeEscalation: false
      readOnlyRootFilesystem: true
      capabilities:
        drop:
        - ALL
        add:
        - NET_BIND_SERVICE
        - SYS_PTRACE # Requis pour l'agent Instana
    resources:
      limits:
        memory: "2Gi"
        cpu: "1000m"
      requests:
        memory: "512Mi"
        cpu: "200m"
```

Network Policies

```
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: instana-agent-netpol
spec:
  podSelector:
    matchLabels:
      app: instana-agent
  policyTypes:
```

```
- Egress
egress:
- to:
  - namespaceSelector: {}
  ports:
  - protocol: TCP
    port: 443 # Backend Instana
- to:
  - podSelector: {}
  ports:
  - protocol: TCP
    port: 42699 # Agent communication
```

Évaluation du Risque

Niveau de Risque Global: MOYEN ●

Justification:

- ✓ Aucune vulnérabilité CRITICAL
- ✓ Composants Java (sensors) sans vulnérabilités
- ⚠ 9 vulnérabilités HIGH dans les bibliothèques système
- ⚠ 110 vulnérabilités MEDIUM nécessitant surveillance
- ✓ 1 correctif HIGH disponible (libnghttp2)

Facteurs Atténuants

- Isolation conteneur** - L'agent s'exécute dans un conteneur isolé
- Principe du moindre privilège** - Peut être configuré avec des capacités limitées
- Image de base officielle** - Support et mises à jour Red Hat
- Composants métier sains** - Les sensors Instana n'ont pas de vulnérabilités

Facteurs Aggravants

- RHEL 8.10** - Approche de la fin de support standard
- Bibliothèques système anciennes** - Versions datées de curl, glibc, etc.
- Pas de correctifs immédiats** - Pour 8 des 9 vulnérabilités HIGH

Comparaison avec les Versions Précédentes

Pour évaluer l'évolution de la sécurité, il est recommandé de :

- Scanner les versions précédentes (1.315.x, 1.314.x)
- Comparer le nombre et la sévérité des CVEs
- Identifier les tendances (amélioration/dégradation)

```
# Exemple de scan comparatif
for version in 1.314.1 1.315.1 1.316.1; do
    skopeo copy docker://containers.instana.io/instana/release/agent/static:$version \
        docker-archive:instana-agent-$version.tar
    trivy image --format json --output instana-agent-$version.json \
        instana-agent-$version.tar
done
```



Recommandations Finales

Pour l'Environnement de Production

1. ✅ **Déployer la version 1.316.1** - Le niveau de risque est acceptable
2. ⚠️ **Appliquer les mesures de mitigation** - SecurityContext, NetworkPolicies
3. 🔄 **Planifier la mise à jour libnghttp2** - Dès que possible
4. 📅 **Planifier la migration RHEL 9** - Dans les 6-12 prochains mois

Pour l'Équipe de Sécurité

1. 🔍 **Scans automatisés** - Intégrer Trivy dans la CI/CD
2. 📊 **Tableau de bord** - Suivre l'évolution des vulnérabilités
3. 🚨 **Alertes** - Notifications pour les nouvelles CVEs CRITICAL/HIGH
4. 📖 **Documentation** - Maintenir un registre des décisions de sécurité

Pour l'Équipe DevOps

1. 🐳 **Image de base** - Évaluer ubi9-minimal pour les futures versions
2. 🛠️ **Automatisation** - Scripts de mise à jour et de test
3. 📦 **Registre privé** - Considérer un registre interne avec scanning
4. 🔐 **Signature d'images** - Implémenter Cosign/Notary pour la vérification



Ressources Utiles

- [Red Hat Security Advisories](#)
- [Trivy Documentation](#)
- [Instana Agent Documentation](#)
- [NIST National Vulnerability Database](#)
- [CVE Details](#)

Date du rapport: 2026-04-15

Analyste: Bob (AI Security Analyst)

Version du document: 1.0